Informe de Auditoría de Seguridad: WebGoat 8.1

Realizado por: Nicolás Navares

Fecha: 12 de enero de 2026

Proyecto: Auditoría web básica - Módulo Introducción a la Ciberseguridad

1. Ámbito y alcance de la auditoría

Este análisis se centra en la aplicación web **WebGoat 8.1.0**, desplegada mediante un contenedor **Docker** en un entorno local (127.0.0.1:8080) . El objetivo es identificar y documentar las vulnerabilidades críticas indicadas en el plan de estudios, siguiendo el estándar del **OWASP Top 10**.

2. Informe ejecutivo

a. Breve resumen del proceso realizado

Se ha llevado a cabo un análisis de seguridad que comenzó con una fase de reconocimiento de red para identificar la infraestructura del servidor. Posteriormente, se procedió a la explotación manual de fallos de inyección, configuración y autenticación, utilizando herramientas como **Nmap** y **Burp Suite** para validar los riesgos detectados.

b. Vulnerabilidades destacadas

- **Inyecciones (A3):** Manipulación de consultas SQL para extraer información masiva y modificar datos financieros.
- **Configuración XML Incorrecta (A5):** Uso de entidades externas (XXE) para comprometer la privacidad del sistema de archivos.
- **Gestión de Autenticación (A7):** Mecanismos de recuperación de cuenta débiles basados en información predecible.

c. Conclusiones

La aplicación WebGoat presenta un nivel de riesgo elevado. La ausencia de mecanismos de validación y sanitización en las entradas del usuario permite que un atacante comprometa la integridad y confidencialidad de la base de datos y del sistema operativo.

d. Recomendaciones generales

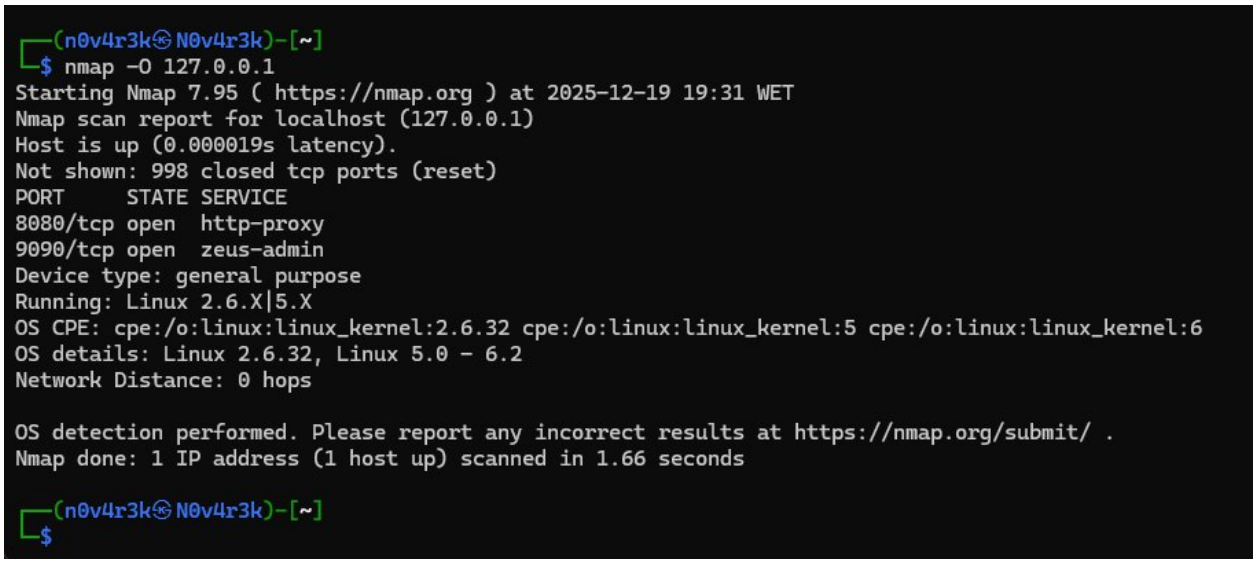
Es muy importante implementar el principio de "defensa en profundidad", aplicando validaciones tanto en el lado del cliente como del servidor, utilizando consultas parametrizadas y reforzando los controles de acceso con factores de autenticación múltiple.

3. **Descripción del proceso de auditoría**

a. Reconocimiento / Information gathering

Se realizó un escaneo con **Nmap** para determinar los servicios activos .

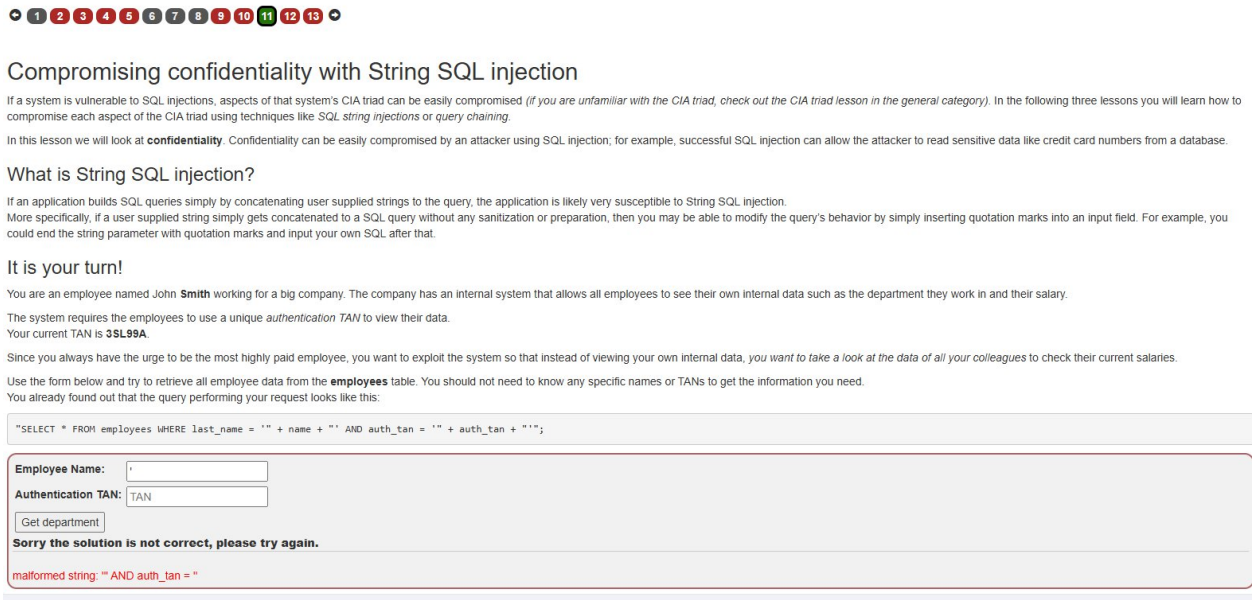
- **Puertos:** Puerto **8080** abierto (Apache Tomcat) y puerto **9090** (Zeus-admin).
- **Sistema Operativo:** Se identificó un entorno **Linux 2.6.X|5.X**.

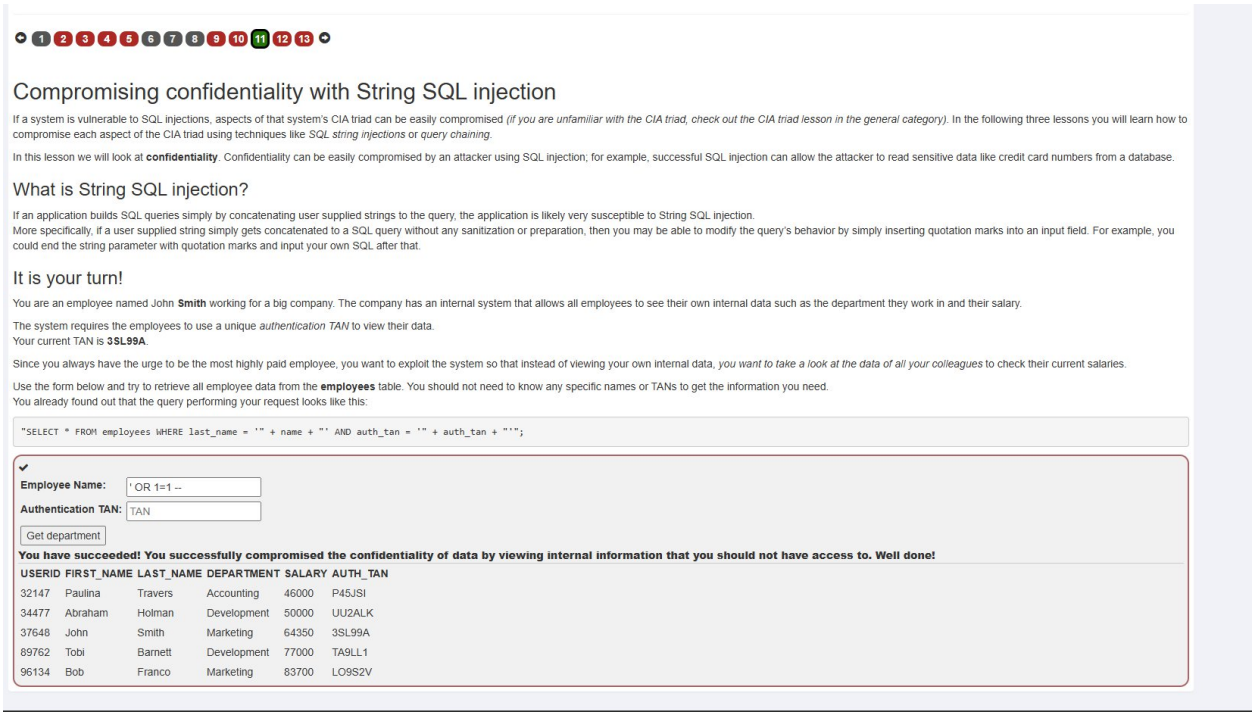


b. Explotación de vulnerabilidades detectadas

1. A3 Injection - SQL Injection (Confidencialidad)

- **Proceso:** Se inyectó la cadena ' OR 1=1 -- en el campo de búsqueda de empleados. El sistema, al no filtrar la entrada, aceptó la condición como verdadera para todos los registros.



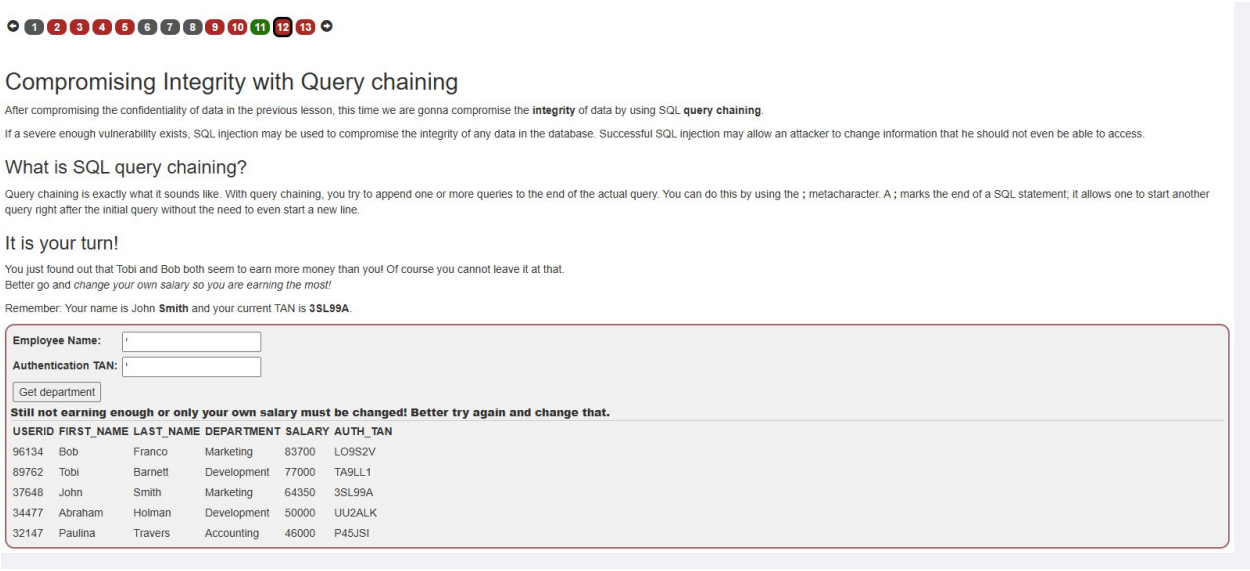


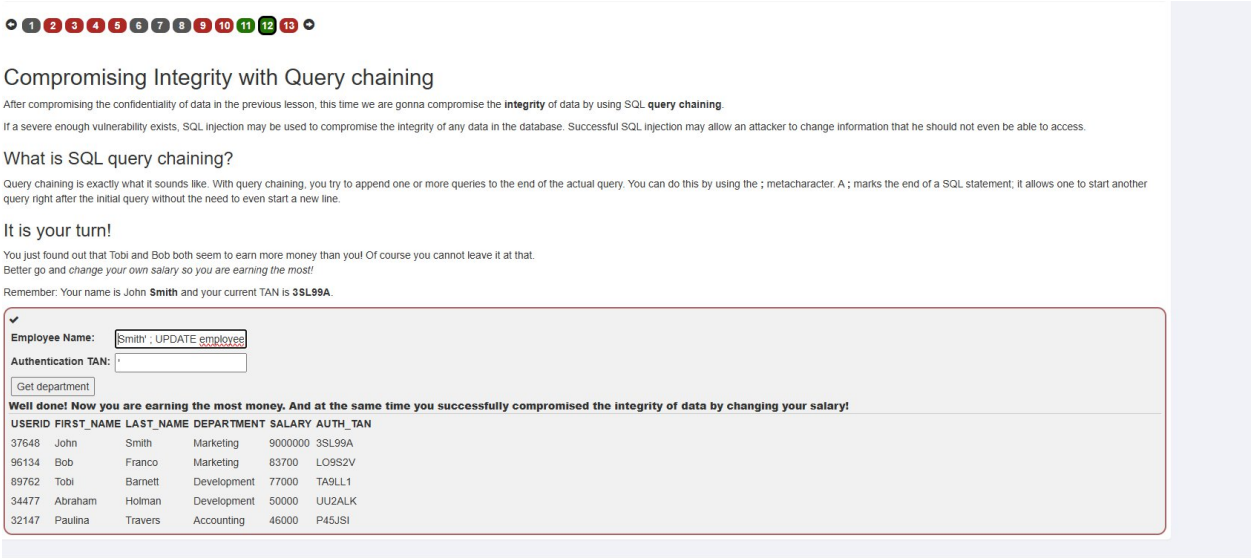
- **Conclusiones:** La falta de sanitización permite saltarse la lógica de la consulta, exponiendo datos privados como salarios y códigos TAN de toda la plantilla.
- **Recomendaciones / Mitigación:** Se debe utilizar **sentencias preparadas (Prepared Statements)** para que el motor de la base de datos trate la entrada del usuario como texto y no como código ejecutable.

2. A3 Injection - SQL Injection (Integridad - Query Chaining)

- **Proceso:** Se utilizó el comando ; UPDATE employees SET salary = 9000000 WHERE last_name = 'Smith' -- para encadenar una segunda instrucción a la consulta original.

Smith' ; UPDATE employees SET salary = 9000000 WHERE last_name = 'Smith' --

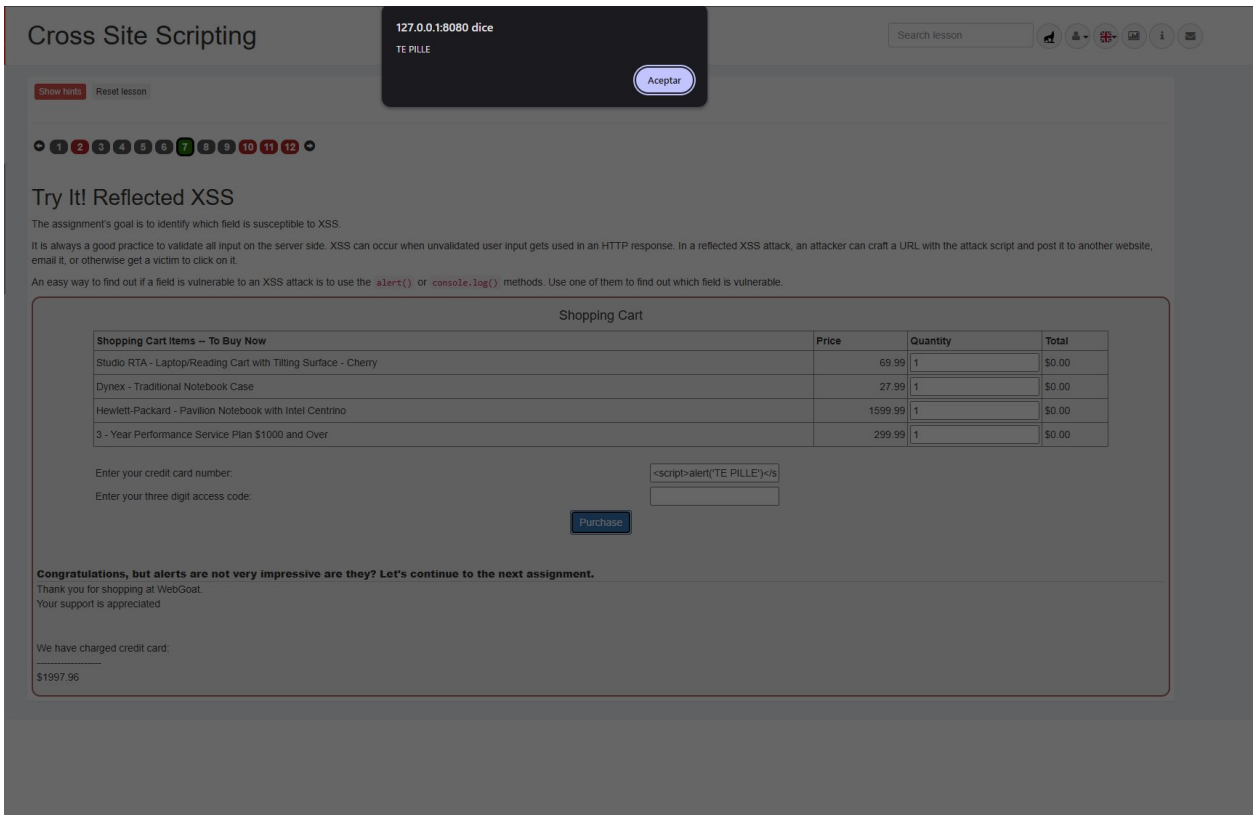




- **Conclusiones:** El sistema permite la ejecución de múltiples consultas en una sola línea, lo que permite a un atacante modificar cualquier dato de la base de datos sin autorización.
- **Recomendaciones / Mitigación:** Desactivar el soporte para consultas múltiples en el driver de conexión y emplear parámetros tipados en las consultas SQL.

3. A3 Injection - Cross Site Scripting (Apartado 7)

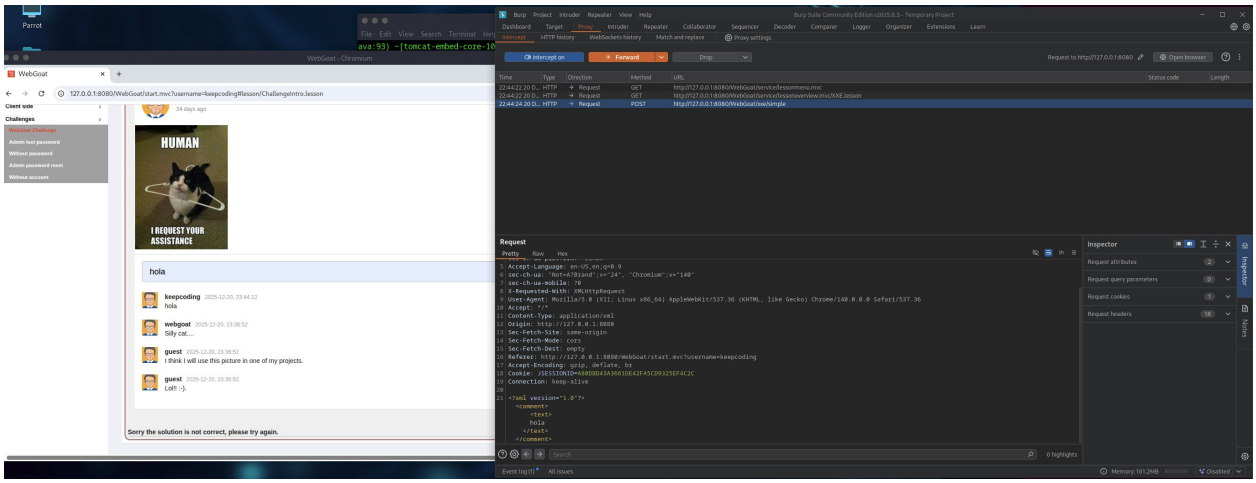
- **Proceso:** Se introdujo <script>alert('TE PILLE')</script> en el campo de la tarjeta de crédito. Al procesar el formulario, el navegador ejecutó el script de forma inmediata.

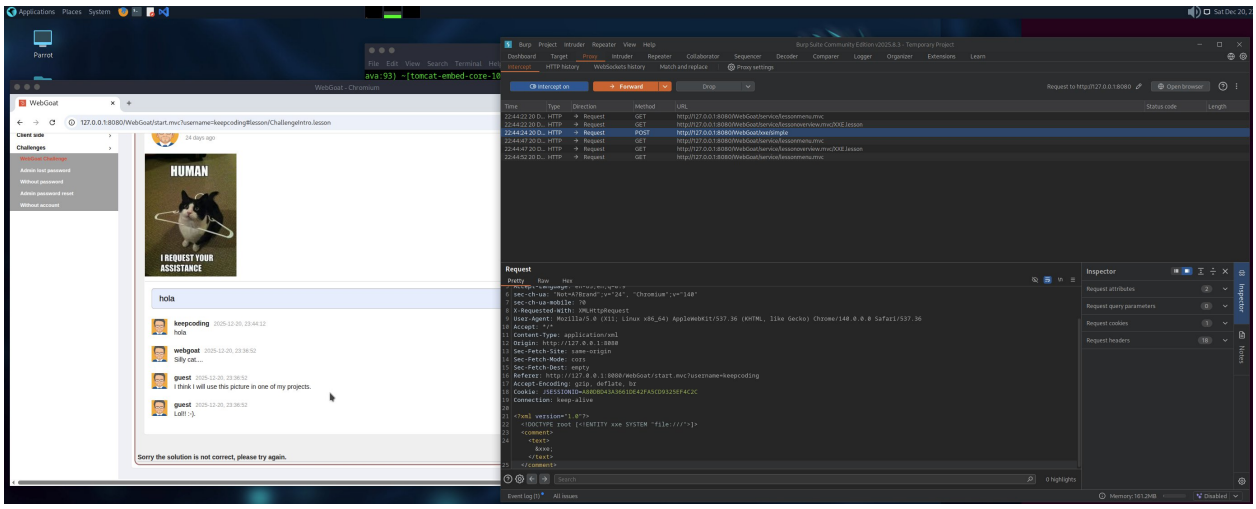


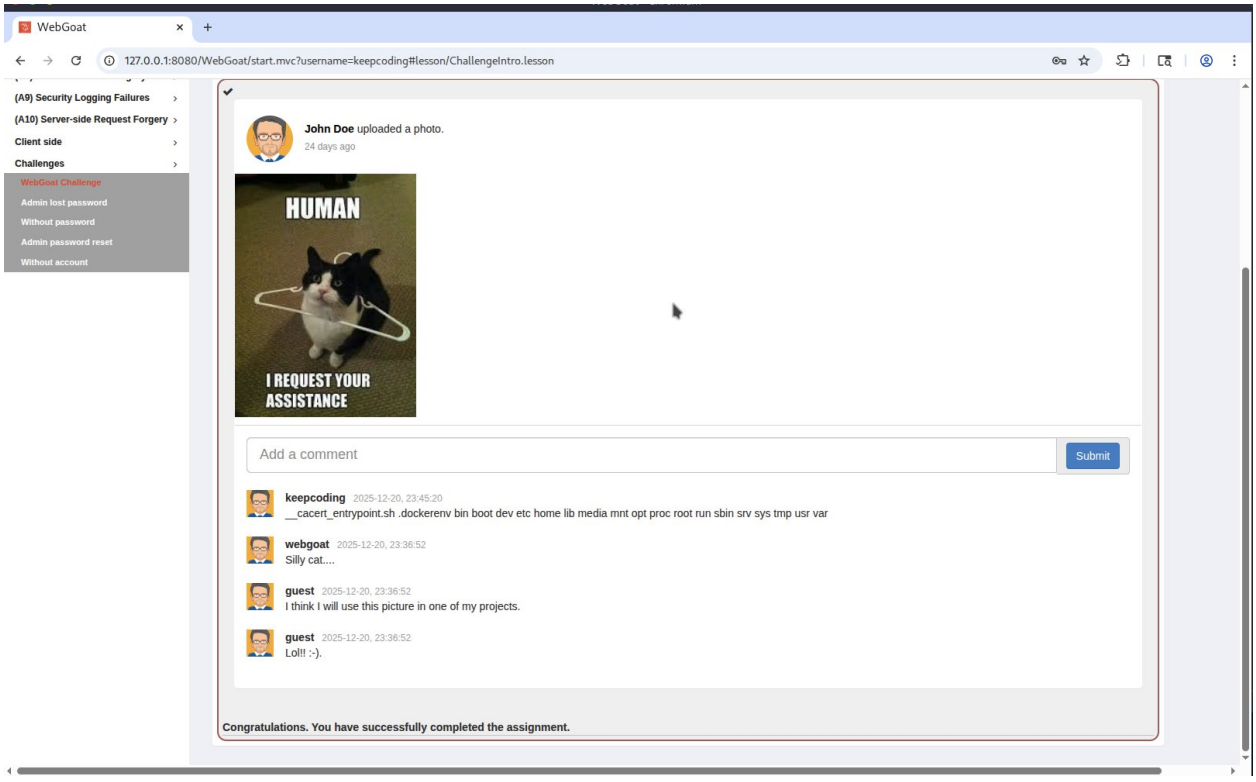
- **Conclusiones:** El fallo es un XSS reflejado; el servidor devuelve el script al navegador del usuario sin codificarlo, lo que podría usarse para robar cookies de sesión.
- **Recomendaciones / Mitigación:** Implementar **codificación de salida (Output Encoding)** para que caracteres como < y > se conviertan en entidades HTML seguras.

4. A5 Security Misconfiguration - XXE (Apartado 4)

- **Proceso:** Mediante **Burp Suite**, se modificó una petición XML para definir una entidad externa que apunta a la raíz del sistema: <!ENTITY xxe SYSTEM "file:///">.



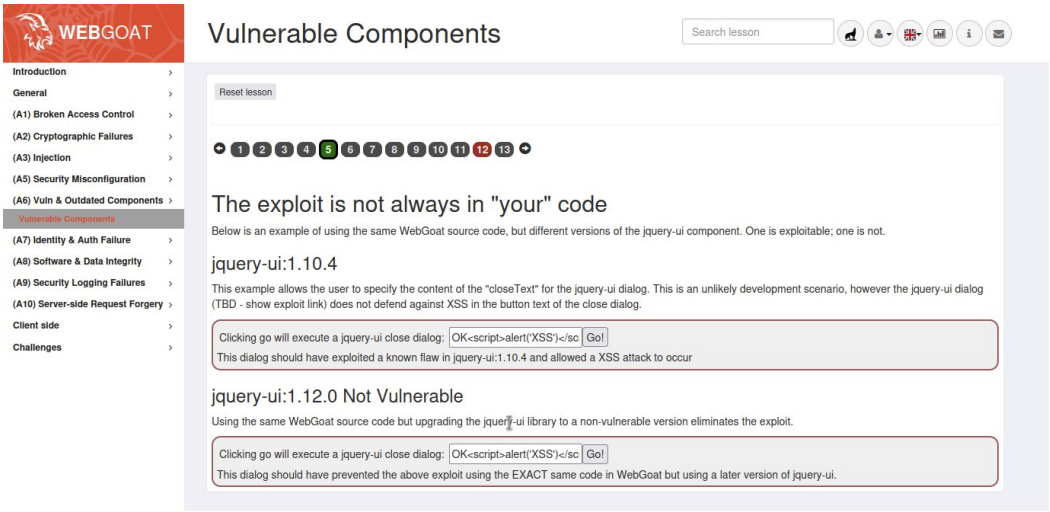




- **Conclusiones:** El procesador de XML del servidor permite entidades externas, lo que resulta en una vulnerabilidad de **Local File Inclusion (LFI)** que expone archivos del sistema operativo.
- **Recomendaciones / Mitigación:** Configurar el procesador XML para **deshabilitar DTDs** y entidades externas completamente.

5. A6 Vuln & Outdated Components (Apartado 5)

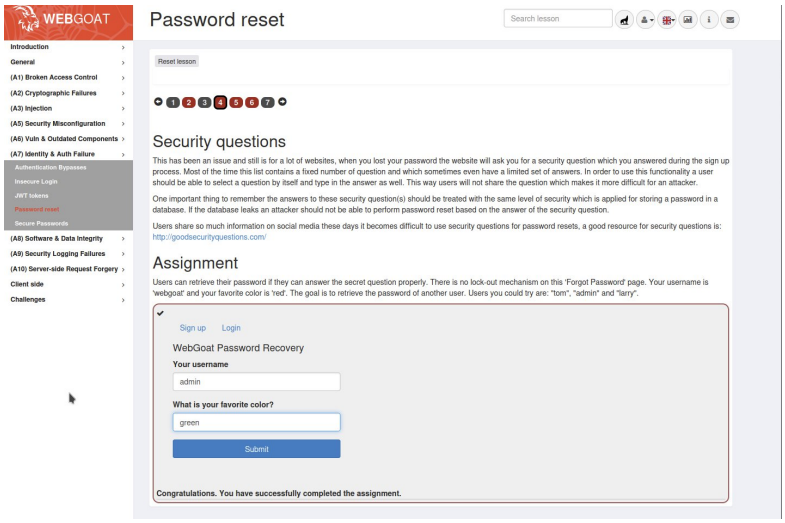
- **Proceso:** Se identificó el uso de la librería **jquery-ui:1.10.4**, comparando su comportamiento con la versión **1.12.0**.



- **Conclusiones:** El uso de componentes antiguos hereda vulnerabilidades ya documentadas (CVEs) que pueden ser explotadas por terceros.
- **Recomendaciones / Mitigación:** Mantener un inventario de dependencias y establecer una política de actualizaciones periódicas a versiones estables y segurizadas.

6. A7 Identity & Auth Failure - Secure Passwords (Apartado 4)

- **Proceso:** Se realizó un bypass del sistema de recuperación de cuenta del usuario "admin" utilizando la respuesta predecible "green" para su color favorito.



- **Conclusiones:** Las preguntas de seguridad son mecanismos débiles porque se basan en información que no es secreta y puede ser adivinada o investigada .
- **Recomendaciones / Mitigación:** Eliminar las preguntas de seguridad y sustituirlas por **Doble Factor de Autenticación (2FA)** o enlaces de recuperación enviados a canales verificados (email/móvil) .

c.

Post-explotación

Tras las pruebas, se confirmó que el acceso obtenido permite la persistencia en la base de datos y la capacidad de pivotar hacia el sistema operativo a través del fallo XXE, lo que otorga un control casi total sobre la información almacenada.

d.

Herramientas utilizadas

- **Nmap:** Escaneo de puertos y reconocimiento de servicios.
- **Burp Suite (Proxy):** Interceptación y manipulación de tráfico XML/HTTP.
- **WebGoat 8.1.0:** Entorno de auditoría vulnerable.